

Содержание

1

Отчёт по CVE в Ozone — полная матрица, одна строка на CVE (скан cve_oz.md)

1

1.1

Пояснения по эксплуатируемости

7

E1

— Клиентский коннектор файловой системы, не на classpath ни одного сервера.

7

E2

— Межузловой транспорт Ratis (shaded netty), только «сервер-сервер».

7

E3

— HTTP веб-интерфейс (Jetty), включён по умолчанию.

7

E4

— Разбор protobuf/netty в RPC/gRPC Ozone.

7

E5

— Плагин Ranger: только на ОМ, за флагом авторизации.

8

E6

— Уязвимый примитив никогда не выбирается (фантомный CRITICAL).

8

E7

— spring в Ozone — только spring-jdbc/jOOQ (Recon).

8

E8

— Клиентский TLS-MITM; Ozone не запускает Thrift-сервер.

8

E9

— Локальный доступ либо опциональный/внутрикластерный компонент.

8

E10

— MITM на пути DNS, только внутри кластера; исправление заблокировано.

8

E11

— Недоверенный вход не доходит до уязвимого парсера.

9

E12

— Разбор JWT, только если настроена JWT-аутентификация.

9

1.2

Итог

9

1 Отчёт по CVE в Ozone — полная матрица, одна строка на CVE (скан cve_oz.md)

Дата: 8 сентября 2026 · **Объект:** образ Ozone 1.4.1.13.079 · **Сверено с:** репозиторий SDP0ZN-2805-fix-cve-issues + плагин Ranger component-ranger-plugins · **Входные данные:** ~/JavaProjects/ozone/cve_oz.md

Это полностью развёрнутый вариант: каждая CVE из скана вынесена в отдельную строку — всего 133 — включая уже исправленные в новой сборке. Сгруппированный вид — в Ozone-CVE-Report-Table-RU.md. **Приоритет** несёт статус исправления и серьёзность конкретной CVE; столбец **Эксплуат.** ссылается на общие сноски о достижимости **E1-E12** ниже.

Скан относится к более старой сборке 1.4.1.13.079, предшествующей большинству исправлений этой сессии. Строки с ✓ уже исправлены на ветке / в репозитории Ranger — **пересборка образа их закрывает** — но здесь они приведены полностью для полноты картины.

Легенда приоритетов — ✓ <цель> уже устранено (закрывается пересборкой; <цель> = исправленная версия, пересборка = shaded-jar клиента получает обновление ветки при пересборке) · **P2** открыто и достижимо на поверхности по умолчанию · **P3** открыто, но не эксплуатируется в текущем развёртывании. Хвост · **SEV** — серьёзность этой конкретной CVE по скану.

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
bcprov-jdk18on 1.77	CVE-2025-14813	✓ 1.84 · CRIT	E6
bcprov-jdk18on 1.77	CVE-2024-34447	✓ 1.84 · MED	E6
bcprov-jdk18on 1.77	CVE-2024-30172	✓ 1.84 · MED	E6
bcprov-jdk18on 1.77	CVE-2024-30171	✓ 1.84 · MED	E6
bcprov-jdk18on 1.77	CVE-2024-29857	✓ 1.84 · MED	E6
commons-configuration2 2.10.1	CVE-2026-45205	P3 · MED	E11

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
commons-configuration2 2.8.0 · ranger-ozone-plugin-impl	CVE-2026-45205	P3 · MED	E5
commons-configuration2 2.8.0 · ranger-ozone-plugin-impl	CVE-2024-29133	P3 · MED	E5
commons-configuration2 2.8.0 · ranger-ozone-plugin-impl	CVE-2024-29131	P3 · MED	E5
commons-lang 2.6	CVE-2025-48924	P3 · MED	E11
commons-lang3 3.14.0 · ozone-filessystem-hadoop2	CVE-2025-48924	P3 · MED	E1
dnsjava 2.1.7	CVE-2024-25638	P3 · HIGH	E10
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2023-31418	✓ 7.17.29 · HIGH	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2025-37731	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2025-37727	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2024-52979	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2024-43709	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2024-23450	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2024-23444	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2023-49921	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2023-46673	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2023-31419	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2023-31417	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2021-22144	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2021-22135	✓ 7.17.29 · MED	E5
elasticsearch 7.10.2 · ranger-ozone-plugin-impl	CVE-2021-22134	✓ 7.17.29 · MED	E5
elasticsearch-rest-client 7.10.2 · ranger-ozone-plugin-impl	CVE-2021-22145	✓ 7.17.29 · MED	E5
hadoop-common 3.3.6	CVE-2024-23454	P3 · LOW	E9

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
httpClient 4.5.6 · ranger-ozone-plugin-impl	CVE-2020-13956	P3 · MED	E5
jackson-core 2.15.0 · ozone-filessystem-hadoop3-client	GHSA-72hv-8253-57qq	✓ пересборка · HIGH	E1
jackson-core 2.11.3 · htrace-core4-shaded (ranger)	CVE-2025-52999	P3 · HIGH	E5
jackson-core 2.11.3 · htrace-core4-shaded (ranger)	GHSA-72hv-8253-57qq	P3 · HIGH	E5
jackson-databind 2.15.0 · ozone-filessystem-hadoop2	CVE-2026-59888	✓ пересборка · MED	E1
jackson-databind 2.15.0 · ozone-filessystem-hadoop2	CVE-2026-54515	✓ пересборка · MED	E1
jackson-databind 2.15.0 · ozone-filessystem-hadoop2	CVE-2026-54514	✓ пересборка · MED	E1
jackson-databind 2.15.0 · ozone-filessystem-hadoop2	CVE-2026-54513	✓ пересборка · HIGH	E1
jackson-databind 2.15.0 · ozone-filessystem-hadoop2	CVE-2026-54512	✓ пересборка · HIGH	E1
jackson-databind 2.11.3 · htrace-core4-shaded (ranger)	CVE-2026-54515	P3 · MED	E5
jackson-databind 2.11.3 · htrace-core4-shaded (ranger)	CVE-2026-54514	P3 · MED	E5
jackson-databind 2.11.3 · htrace-core4-shaded (ranger)	CVE-2026-54513	P3 · HIGH	E5
jackson-databind 2.11.3 · htrace-core4-shaded (ranger)	CVE-2026-54512	P3 · HIGH	E5
jackson-databind 2.11.3 · htrace-core4-shaded (ranger)	CVE-2026-50193	P3 · HIGH	E5
jackson-databind 2.11.3 · htrace-core4-shaded (ranger)	CVE-2022-42004	P3 · HIGH	E5
jackson-databind 2.11.3 · htrace-core4-shaded (ranger)	CVE-2022-42003	P3 · HIGH	E5
jackson-databind 2.11.3 · htrace-core4-shaded (ranger)	CVE-2021-46877	P3 · HIGH	E5
jackson-databind 2.11.3 · htrace-core4-shaded (ranger)	CVE-2020-36518	P3 · HIGH	E5
jetty-http 9.4.57	CVE-2026-2332	P2 · HIGH	E3
jetty-http 9.4.57	CVE-2025-11143	P2 · LOW	E3
jetty-http 9.4.57	CVE-2024-6763	P2 · LOW	E3
jetty-security 9.4.57	CVE-2026-10050	P3 · HIGH	E3
jetty-server 9.4.57	CVE-2026-6790	P3 · MED	E3

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
libthrift 0.14.1	CVE-2026-43869	P3 · HIGH	E8
netty-codec 4.1.128	CVE-2026-59901	✓ 4.1.137 · HIGH	E4
netty-codec 4.1.128	CVE-2026-42583	✓ 4.1.137 · HIGH	E4
netty-codec 4.1.100 · ozone-filessystem-hadoop2	CVE-2026-59901	✓ пересборка · HIGH	E1
netty-codec 4.1.100 · ozone-filessystem-hadoop2	CVE-2026-42583	✓ пересборка · HIGH	E1
netty-codec-dns 4.1.100 · ratis-thirdparty-misc	CVE-2026-73508	✓ 1.1.0 · MED	E2
netty-codec-dns 4.1.100 · ratis-thirdparty-misc	CVE-2026-42579	✓ 1.1.0 · HIGH	E2
netty-codec-http 4.1.128	CVE-2026-59921	✓ 4.1.137 · MED	E4
netty-codec-http 4.1.128	CVE-2026-59903	✓ 4.1.137 · MED	E4
netty-codec-http 4.1.128	CVE-2026-56746	✓ 4.1.137 · MED	E4
netty-codec-http 4.1.128	CVE-2026-50020	✓ 4.1.137 · MED	E4
netty-codec-http 4.1.128	CVE-2026-42585	✓ 4.1.137 · MED	E4
netty-codec-http 4.1.128	CVE-2026-42581	✓ 4.1.137 · MED	E4
netty-codec-http 4.1.128	CVE-2026-42580	✓ 4.1.137 · MED	E4
netty-codec-http 4.1.128	CVE-2026-41417	✓ 4.1.137 · MED	E4
netty-codec-http 4.1.128	CVE-2025-67735	✓ 4.1.137 · MED	E4
netty-codec-http 4.1.128	CVE-2026-56745	✓ 4.1.137 · HIGH	E4
netty-codec-http 4.1.128	CVE-2026-55833	✓ 4.1.137 · HIGH	E4
netty-codec-http 4.1.128	CVE-2026-55831	✓ 4.1.137 · HIGH	E4
netty-codec-http 4.1.128	CVE-2026-42587	✓ 4.1.137 · HIGH	E4
netty-codec-http 4.1.128	CVE-2026-42584	✓ 4.1.137 · HIGH	E4
netty-codec-http 4.1.128	CVE-2026-33870	✓ 4.1.137 · HIGH	E4
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-59921	✓ пересборка · MED	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-59903	✓ пересборка · MED	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-56746	✓ пересборка · MED	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-50020	✓ пересборка · MED	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-42585	✓ пересборка · MED	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-42581	✓ пересборка · MED	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-42580	✓ пересборка · MED	E1

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-41417	✓ пересборка · MED	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2025-67735	✓ пересборка · MED	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2024-29025	✓ пересборка · MED	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-56745	✓ пересборка · HIGH	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-55833	✓ пересборка · HIGH	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-55831	✓ пересборка · HIGH	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-42587	✓ пересборка · HIGH	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-42584	✓ пересборка · HIGH	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-33870	✓ пересборка · HIGH	E1
netty-codec-http 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2025-58056	✓ пересборка · LOW	E1
netty-codec-http2 4.1.100 · ratis-thirdparty-misc	CVE-2026-56819	✓ 1.1.0 · HIGH	E2
netty-codec-http2 4.1.100 · ratis-thirdparty-misc	CVE-2026-42587	✓ 1.1.0 · HIGH	E2
netty-codec-http2 4.1.100 · ratis-thirdparty-misc	CVE-2026-33871	✓ 1.1.0 · HIGH	E2
netty-codec-http2 4.1.100 · ratis-thirdparty-misc	CVE-2025-55163	✓ 1.1.0 · HIGH	E2
netty-codec-http2 4.1.100 · ratis-thirdparty-misc	CVE-2026-50560	✓ 1.1.0 · MED	E2
netty-codec-http2 4.1.100 · ratis-thirdparty-misc	CVE-2026-48043	✓ 1.1.0 · MED	E2
netty-codec-http2 4.1.100 · ratis-thirdparty-misc	CVE-2026-47244	✓ 1.1.0 · MED	E2
netty-codec-http2 4.1.128	CVE-2026-56819	✓ 4.1.137 · HIGH	E4
netty-codec-http2 4.1.128	CVE-2026-42587	✓ 4.1.137 · HIGH	E4
netty-codec-http2 4.1.128	CVE-2026-33871	✓ 4.1.137 · HIGH	E4
netty-codec-http2 4.1.128	CVE-2026-50560	✓ 4.1.137 · MED	E4
netty-codec-http2 4.1.128	CVE-2026-48043	✓ 4.1.137 · MED	E4
netty-codec-http2 4.1.128	CVE-2026-47244	✓ 4.1.137 · MED	E4

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
netty-common 4.1.100 · ozone-filessystem-hadoop2	CVE-2025-25193	✓ пересборка · MED	E1
netty-common 4.1.100 · ozone-filessystem-hadoop2	CVE-2024-47535	✓ пересборка · MED	E1
netty-handler 4.1.100 · ozone-filessystem-hadoop2	CVE-2026-50010	✓ пересборка · HIGH	E1
netty-handler 4.1.100 · ozone-filessystem-hadoop2	CVE-2026-45416	✓ пересборка · HIGH	E1
netty-handler 4.1.100 · ozone-filessystem-hadoop2	CVE-2026-44249	✓ пересборка · HIGH	E1
netty-handler 4.1.100 · ozone-filessystem-hadoop2	CVE-2025-24970	✓ пересборка · HIGH	E1
netty-handler 4.1.128	CVE-2026-50010	✓ 4.1.137 · HIGH	E4
netty-handler 4.1.128	CVE-2026-45416	✓ 4.1.137 · HIGH	E4
netty-handler 4.1.128	CVE-2026-44249	✓ 4.1.137 · HIGH	E4
netty-handler-proxy 4.1.128 · ozone-filessystem-hadoop3	CVE-2026-42578	✓ пересборка · LOW	E1
netty-resolver-dns 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-47691	✓ пересборка · HIGH	E1
netty-resolver-dns 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-45674	✓ пересборка · HIGH	E1
netty-resolver-dns 4.1.100 · ozone-filessystem-hadoop3-client	CVE-2026-45673	✓ пересборка · MED	E1
nimbus-jose-jwt 9.37.2	CVE-2025-53864	P3 · MED	E12
protobuf-java 3.7.1 · hadoop-shaded-protobuf_3_7	CVE-2024-7254	✓ 3.25.5 · HIGH	E4
protobuf-java 3.7.1 · hadoop-shaded-protobuf_3_7	CVE-2022-3510	✓ 3.25.5 · HIGH	E4
protobuf-java 3.7.1 · hadoop-shaded-protobuf_3_7	CVE-2022-3509	✓ 3.25.5 · HIGH	E4
protobuf-java 3.7.1 · hadoop-shaded-protobuf_3_7	CVE-2021-22570	✓ 3.25.5 · HIGH	E4
protobuf-java 3.7.1 · hadoop-shaded-protobuf_3_7	CVE-2021-22569	✓ 3.25.5 · HIGH	E4
protobuf-java 3.7.1 · hadoop-shaded-protobuf_3_7	CVE-2022-3171	✓ 3.25.5 · MED	E4
protobuf-java 3.19.6	CVE-2024-7254	✓ 3.25.5 · HIGH	E4
protobuf-java 2.5.0	CVE-2024-7254	✓ 3.25.5 · HIGH	E4
protobuf-java 2.5.0	CVE-2021-22570	✓ 3.25.5 · HIGH	E4
protobuf-java 2.5.0	CVE-2021-22569	✓ 3.25.5 · HIGH	E4
protobuf-java 2.5.0	CVE-2022-3171	✓ 3.25.5 · MED	E4

Библиотека (jar · контейнер)	CVE	Приоритет	Эксплуат.
ranger-plugins-common 2.4.0 · ranger-ozone-plugin-impl	CVE-2025-59059	✓ Nashorn · CRIT	E5
spring-core 5.3.27	CVE-2026-41848	✓ 5.3.39 · LOW	E7
spring-core 5.3.27	CVE-2025-41249	✓ 5.3.39 · HIGH	E7
zookeeper 3.8.4	CVE-2026-24308	P3 · HIGH	E9
zookeeper 3.8.4	CVE-2026-24281	P3 · HIGH	E9

1.1 Пояснения по эксплуатируемости

E1 — Клиентский коннектор файловой системы, не на classpath ни одного сервера.

Находка вшита (shaded) в ozone-filessystem-hadoop2/hadoop3/hadoop3-client-*.jar, которого **нет** ни в одном classpath сервисов Ozone (сверено с дескрипторами classpath дистрибутива). Это отдельные коннекторы o3fs:///ofs:// для внешних клиентов Hadoop/Spark/Hive; серверы Ozone их не загружают. Значимо только для клиентского процесса, использующего коннектор — и при пересборке ветки эти shaded-jar также получают исправленные netty 4.1.137 / jackson 2.18.9 (так что открытыми для этого клиента остаются только commons-lang3 и nimbus, которые на ветке не обновлялись).

E2 — Межузловой транспорт Ratis (shaded netty), только «сервер-сервер».

Внутри ratis-thirdparty-misc; используется для gRPC-канала консенсуса Ratis между узлами OM/SCM/DN, клиентам Ozone не доступен. **Уже исправлено** на ветке (ratis-thirdparty 1.0.5 → 1.1.0, shaded netty 4.1.136).

E3 — HTTP веб-интерфейс (Jetty), включён по умолчанию.

Каждый сервис Ozone поднимает Jetty веб-UI/REST-эндпоинт (ozone.om.http.enabled / ozone.scm.http.enabled = true; OM :9874, SCM :9876, Recon :9888, S3G :9878, DN). **CVE-2026-2332** (request smuggling) достижима для любого, кто имеет доступ к веб-порту — это наиболее серьёзная клиентская экспозиция здесь, особенно за service-mesh DropApp. **CVE-2026-10050** (обход digest-аутентификации) **не** достижима: аутентификация HTTP в Ozone — SPNEGO/Kerberos, а не HTTP Digest. **Исправления в OSS-ветке Jetty 9.4 под Java 8 нет** (исправления в 9.4.60/9.4.63 — сборки EOL; Maven Central заканчивается на 9.4.58) — остаётся открытым; митигировать на уровне service-mesh (нормализация chunked-кодирования) либо принять с документированием.

E4 — Разбор protobuf/netty в RPC/gRPC Ozone.

Hadoop-IPC (protobuf) на OM/SCM/DN и gRPC-транспорт разбирают недоверенные сообщения клиентов — реально на поверхности сервера. **Уже устранено** на ветке: protobuf-java → 3.25.5 (устаревший рантайм proto2, gRPC и hadoop-shaded-protobuf_3_7 → _3_25), отдельный netty → 4.1.137. Просканированного protobuf-java-2.5.0.jar в текущем дистрибутиве уже нет.

E5 — Плагин Ranger: только на ОМ, за флагом авторизации.

Jar-файлы ranger-ozone-plugin-impl/* загружаются только если оператор задаёт `ozone.acl.authorizer.class` равным авторизатору Ranger; по умолчанию используется нативный `OzoneAccessAuthorizer` (`ozone.acl.enabled=false`). Elasticsearch — только для аудита и **отключён** (`XAAUDIT.ELASTICSEARCH.ENABLE=false`); RCE через Nashorn в ranger-plugins-common требует управляемых атакующим скриптов политик, которые задаются администратором через сервис Ranger admin; копии `httpClient/htrace` обращаются к доверенному эндпоинту Ranger admin. **ElasticSearch (→ 7.17.29) и песочница Nashorn уже исправлены** в component-ranger-plugins; остальные CVE вендорских jar (`httpClient 4.5.6`, `htrace-shaded jackson`) неактивны, пока Ranger не включён.

E6 — Уязвимый примитив никогда не выбирается (фантомный CRITICAL).

BouncyCastle присутствует в runtime-classpath (SCM CA, TLS, block-токены), но CVE-2025-14813 — в режиме **GOST 28147 CTR**; Ozone использует стандартные AES/RSA/ECDSA и никогда не выбирает GOST 28147. **Уже исправлено** (`bcprov 1.77 → 1.84`, что также закрывает CVE-2026-0636/5588).

E7 — spring в Ozone — только spring-jdbc/jOOQ (Recon).

spring-core на classpath Recon исключительно для jOOQ/JDBC. spring-security `@EnableMethodSecurity` отсутствует, поэтому у CVE-2025-41249 нет достижимой точки вызова. **Уже обновлён** до 5.3.39 (закрывает прочие CVE spring-core; у CVE-2025-41249 нет OSS-исправления на линии 5.3.x, но она в любом случае недостижима).

E8 — Клиентский TLS-MITM; Ozone не запускает Thrift-сервер.

libthrift попадает только через jaeger-thrift (трассировка), которая отключена по умолчанию (`hdds.tracing.enabled=false`), и Ozone **не** запускает Thrift-сервер — libthrift здесь только клиент отправки трасс jaeger. CVE-2026-43869 (CWE-297, отсутствие проверки имени хоста TLS) — слабость клиента при сетевом MITM, поэтому со стороны сервера не эксплуатируется вдвойне.

E9 — Локальный доступ либо опциональный/внутрикластерный компонент.

hadoop-common CVE-2024-23454 (локальное раскрытие временного файла) требует локального доступа к контейнеру. ZooKeeper присутствует только на classpath **httpfs** — ядро Ozone использует Ratis, а не ZK — и ансамбль ZK является доверенным внутрикластерным сервисом; достижимо только при развёртывании httpfs против доступного атакующему ZooKeeper. Обновить ZK → 3.8.6 при случае.

E10 — MITM на пути DNS, только внутри кластера; исправление заблокировано.

Обход DNSSEC в dnsjava требует атакующего на пути DNS; разрешение имён происходит внутри кластера. Исправление **заблокировано вышестоящей зависимостью**: dnsjava 3.x меняет `ResolverConfig.searchPath()` несовместимо с `SecurityUtil$QualifiedHostResolver` из `hadoop-common 3.3.6`, поэтому требуется Hadoop 3.4.x (прежний откат SDPOZN-2492 упёрся ровно в это).

E11 — Недоверенный вход не доходит до уязвимого парсера.

CVE в commons-configuration2 / commons-lang / commons-lang3 — это ошибки DoS/неконтролируемой рекурсии, требующие управляемого атакующим входа в конкретный парсер/метод; Ozone разбирает собственную доверенную конфигурацию. Обновить при случае (commons-configuration2 → 2.15.0, commons-lang3 → 3.18.0) — низкая срочность.

E12 — Разбор JWT, только если настроена JWT-аутентификация.

nimbus-jose-jwt CVE-2025-53864 (DoS через глубоко вложенный JSON) достижима только при включённой JWT-аутентификации на S3G/OM, что не является настройкой по умолчанию (Kerberos / секрет S3). Обновить до 9.37.4 при случае; остаётся открытым.

1.2 Итог

- **Пересобрать образ.** Скан относится к устаревшей сборке 1.4.1.13.079; CRITICAL и подавляющее большинство HIGH-находок — bcsprov, весь protobuf, весь netty (отдельный / ratis / shaded в fs-jar), jackson (сервер + пересобранные fs-jar), spring, а также Elasticsearch и RCE через Nashorn в component-ranger-plugins — **уже исправлены** на SDP0ZN-2805-fix-cve-issues / в репозитории плагина Ranger (✓). Пересборка их закрывает.
- **P2 (реально открыто и достижимо):** request smuggling в веб-UI Jetty 9.4.57 (CVE-2026-2332). Исправления под Java 8 в OSS нет — митигировать на уровне service-mesh либо принять с документированием.
- **P3 (открыто, но не эксплуатируется):** commons-configuration2 → 2.15.0, commons-lang3 → 3.18.0, zookeeper → 3.8.6 (только httpfs), nimbus → 9.37.4; dnsjava (заблокировано → Hadoop 3.4.x) и hadoop-common (→ 3.4.x); а также вендорские httpclient/htrace плагина Ranger, неактивные без включённой авторизации Ranger. Подавить с применимой сноской либо обновить при случае.

Примечание: очевидные опечатки OCR в исходном скане исправлены (VE-2026-.../VE-2024-... → CVE-..., кириллическая С → c, слипы CRITICAL/commons-configuration2 2.20.1). Ссылки на бюллетени без CVE (jackson-core GHSA-72hv-8253-57qq) оставлены как есть. Статус исправления указан по закоммиченному POM ветки SDP0ZN-2805-fix-cve-issues (дистрибутив на диске пересобирался не после каждого обновления); достижимость — из дескрипторов classpath дистрибутива + ozone-default.xml.